



ISC 互联网安全大会



360 互联网安全中心



保护保护者，安全企业CSO的安全挑战

谭晓生

360集团技术总裁，首席安全官

ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing·China

(原“中国互联网安全大会”)

目录

战场
人
事儿
技术



ISC 互联网安全大会



360 互联网安全中心

战 场

ZERO TRUST SECURITY

战场：一个互联网安全公司的战场



100,000+



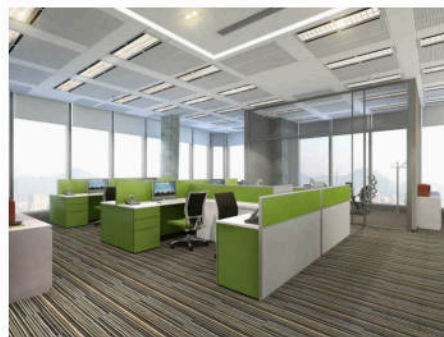
185+



1,000G +



10,000+



10+



5000+

战场：一个互联网安全公司的战场（续）



程序员

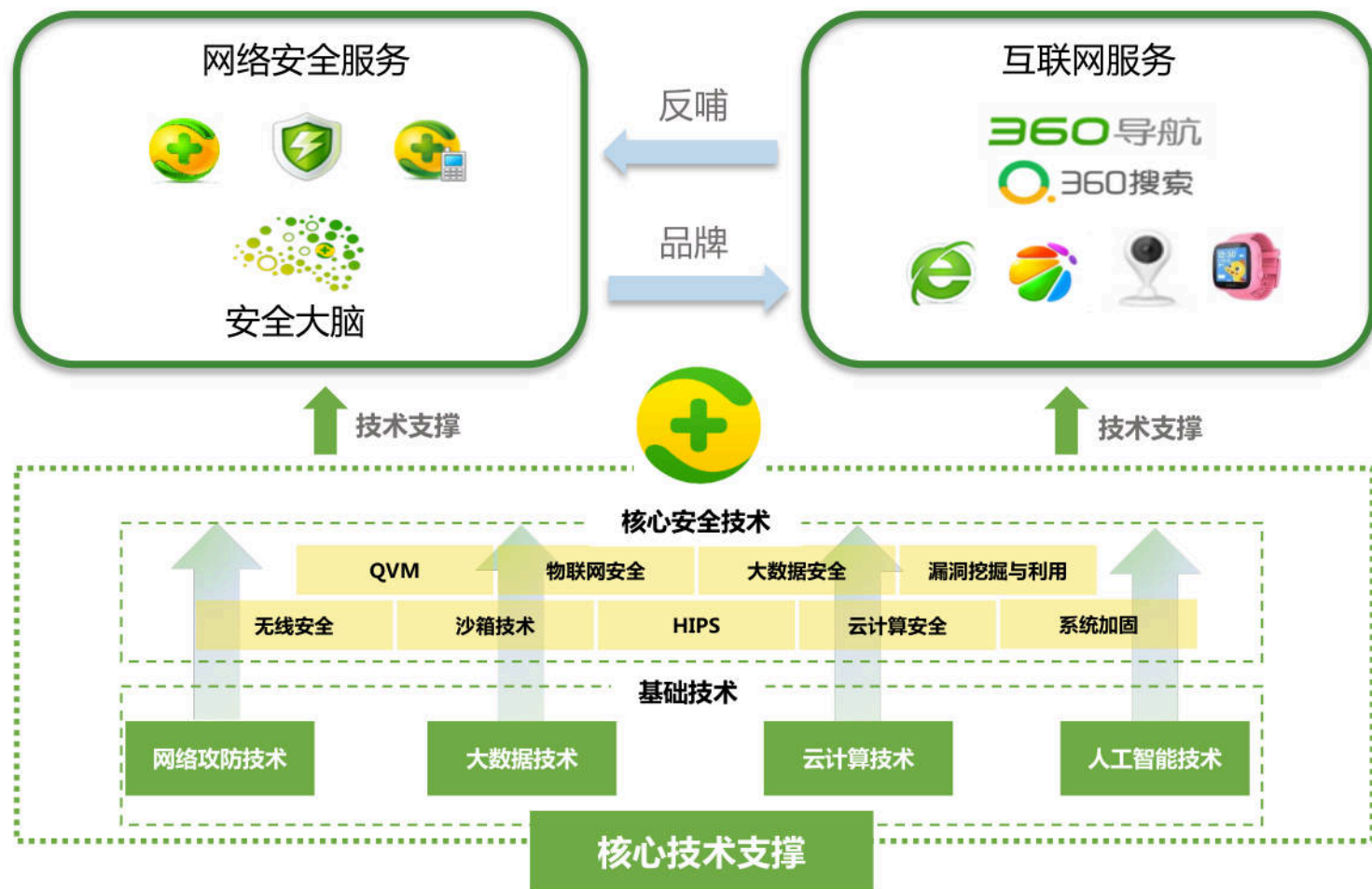


外部黑客



内部人威胁

战场：一个互联网安全公司的战场（续）





ISC 互联网安全大会



360 互联网安全中心

人

ZERO TRUST SECURITY

老板

高管

安全团队

安全圈同仁

监管部门领导



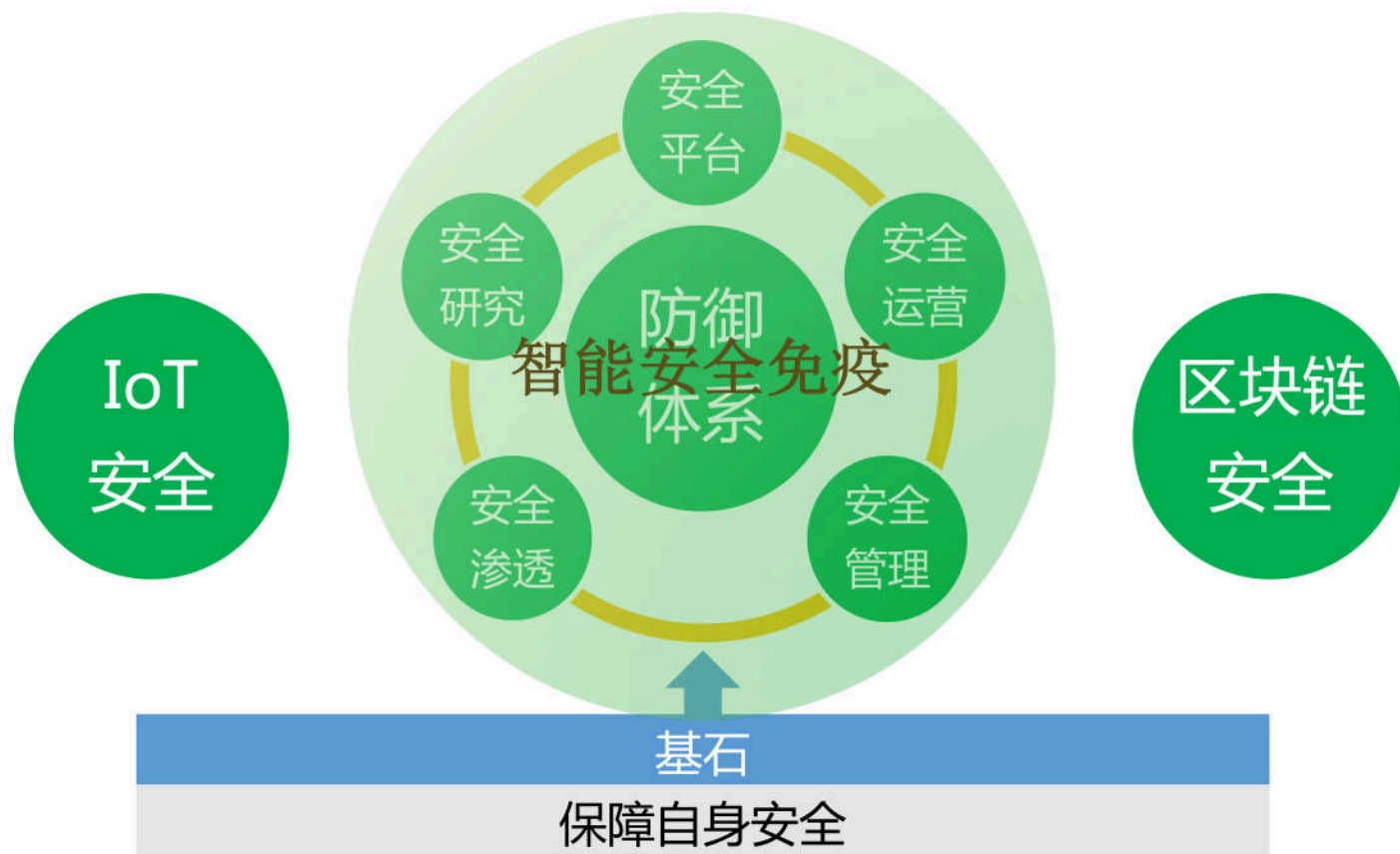
ISC 互联网安全大会

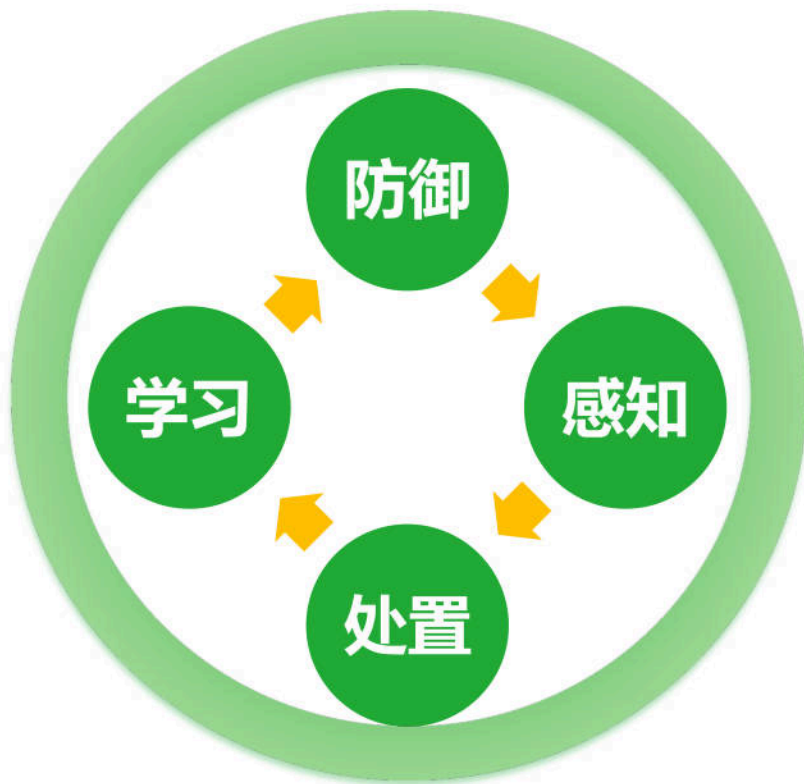


360 互联网安全中心

事儿

ZERO TRUST SECURITY





红军

业务安全

数据安全

系统安全

- WEB、移动、服务器端、IoT共**2,806**次
- 涉及**210**条业务线
- 总计发现漏洞**3,032**个，其中SRC上报**327**个，接近**11%**
- 高危以上漏洞内部发现**1,793**个，SRC上报**21**个，占比**1%**



信息安全意识专项培训



ISC 互联网安全大会



360 互联网安全中心

搜索业务线 **79%**

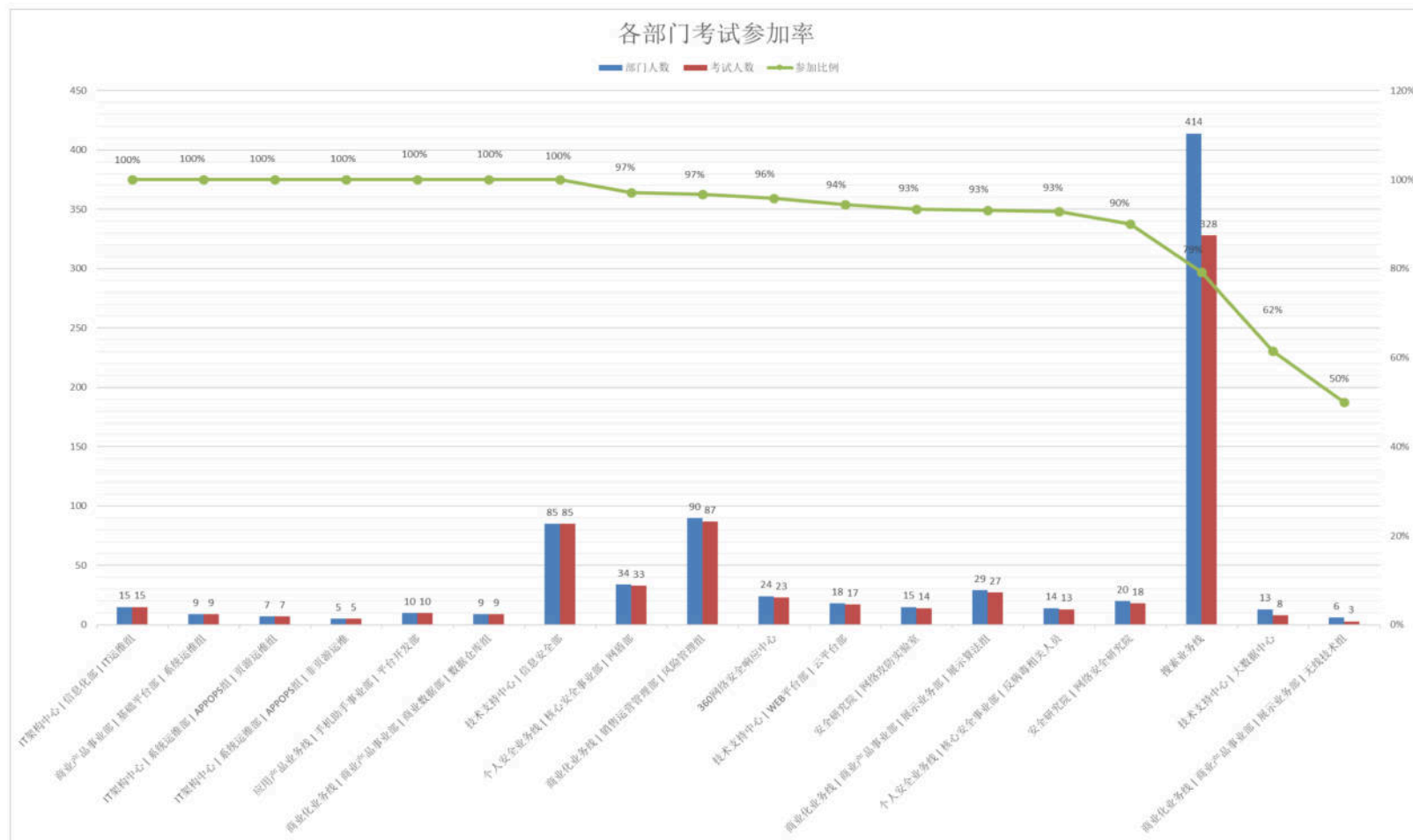
- 考试人数328
- 缺考人数86

技术支持中心-大数据中心 **62%**

- 考试人数 8
- 缺考人数 5

商业化业务线-商业产品事业部-无线技术组 **50%**

- 考试人数 3
- 缺考人数 3





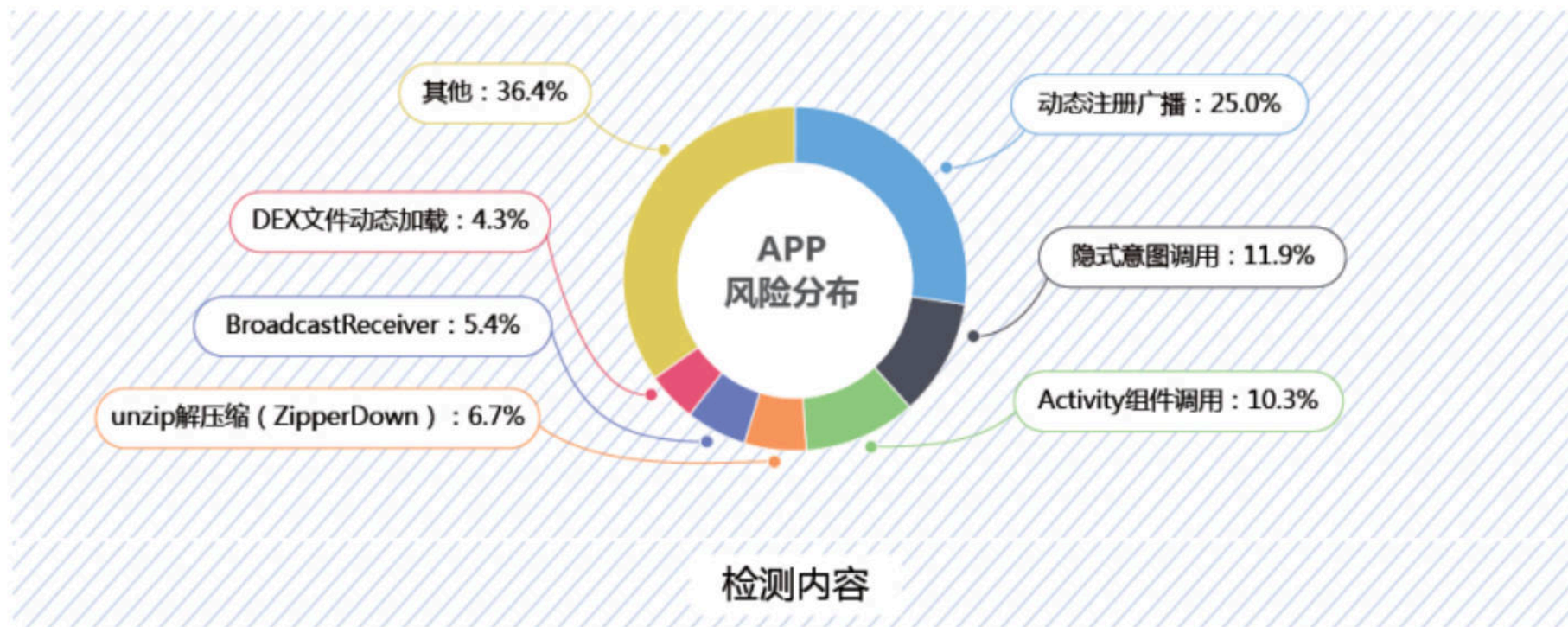
ISC 互联网安全大会



360 互联网安全中心

技 术

ZERO TRUST SECURITY



自研防御平台：天相-资产测绘与漏洞扫描



ISC 互联网安全大会



360 互联网安全中心

天相

SKYPHENOMENA

任务管理

任务列表

配置管理

扫描目标管理

资产管理

资产列表

IP查询

资产报表

资产拓扑图

被动扫描

开始

漏洞列表

扫描历史

导出管理

指纹管理

应用指纹

在线检测

PoC管理

PoC管理

在线检测

节点管理

消费管理

权限管理

资产管理 / 资产报表

选择任务

扫描记录

刷新



2k+

域名数



1k+

主机数



14k+

端口数



13k+

网站数



580

应用数

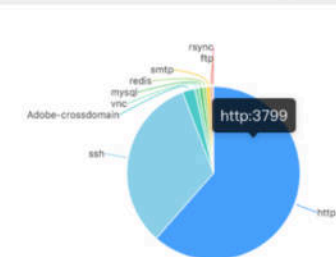


3k+

漏洞数

端口服务分布

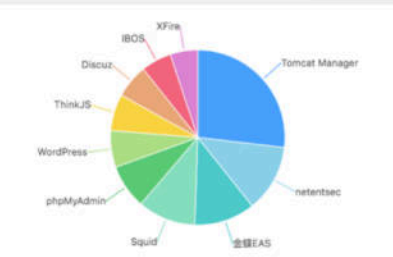
是否外网



http ssh Adobe-crossdomain vnc
mysql redis smtp ftp rsync

应用数量统计

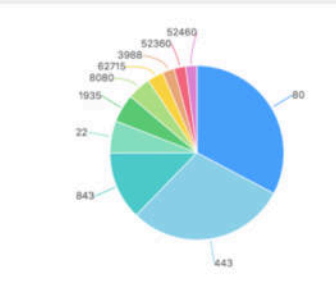
是否外网



Tomcat Manager netentsec 金蝶EAS Squid
phpMyAdmin WordPress ThinkJS Discuz IBOS
XFire

端口数量统计

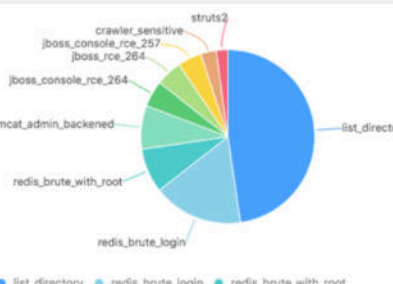
是否外网



80 443 843 22 1935
8080 62715 3988 52360 52460

漏洞类型统计

是否外网



list_directory redis_brute_login redis_brute_with_root
tomcat_admin_backened jboss_console_rce_264 jboss_console_rce_257
crawler_sensitive struts2

漏洞内外网统计

内网 外网 未知



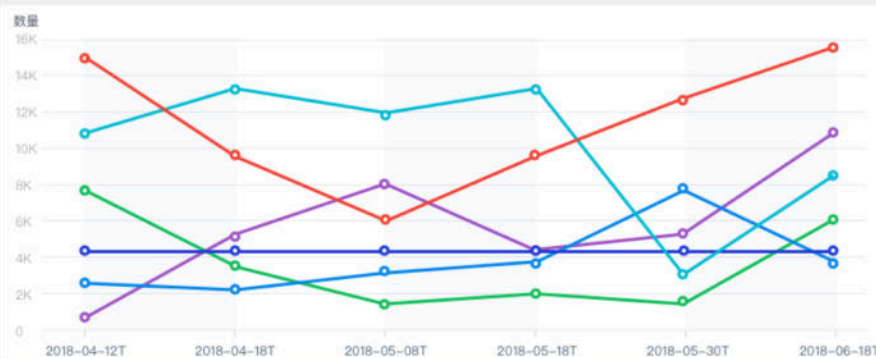
ASN组织

主机数量

IDC, China Telecommunications Corporation	276
Hangzhou Alibaba Advertising Co.,Ltd.	272
China Unicom Beijing Province Network	175
Shenzhen Tencent Computer Systems Company Limited	172
Beijing Qihu Technology Company Limited	98
No.31,Jin-rong Street	92
China Telecom (Group)	82
Guangdong Mobile Communication Co.Ltd.	60

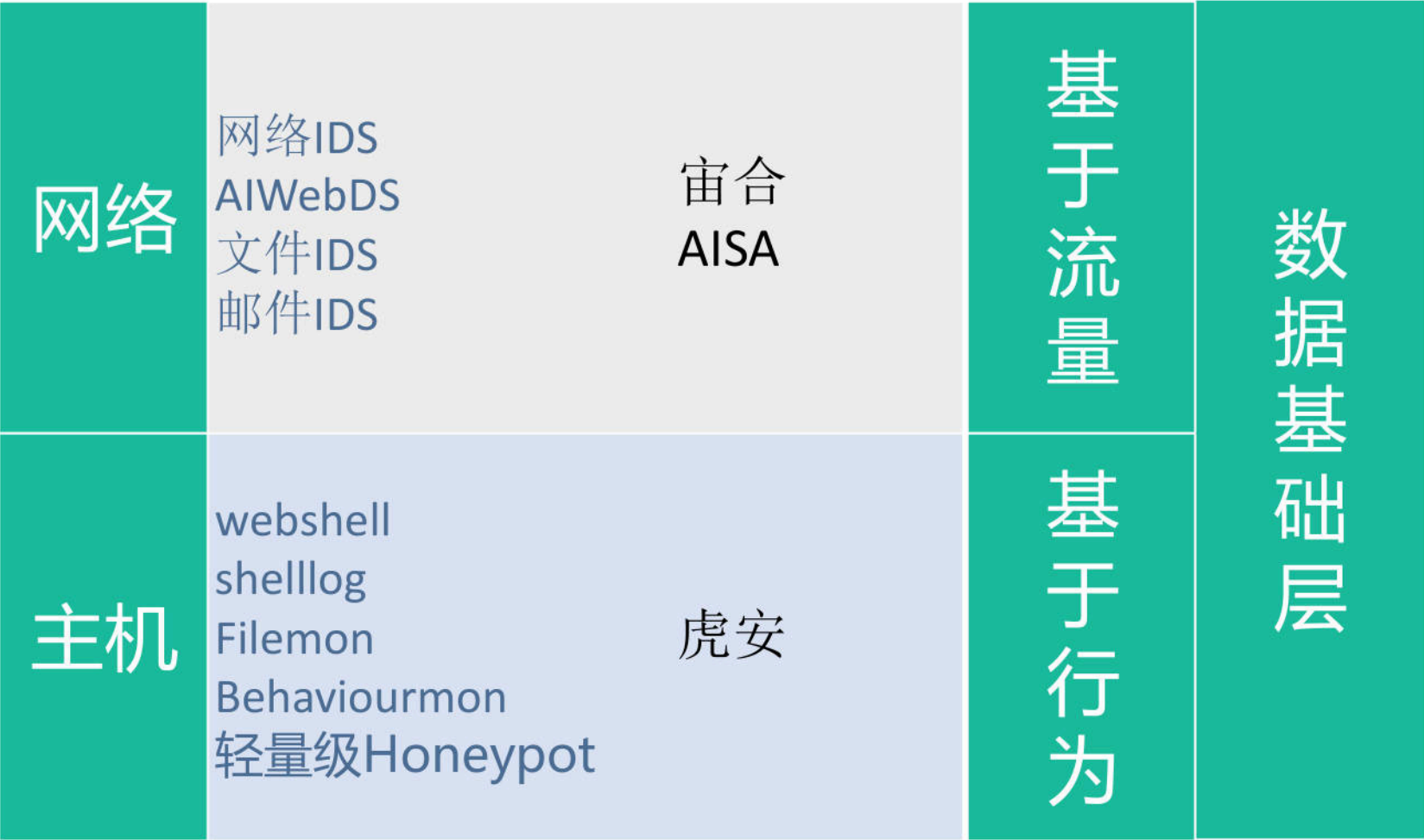
资产数量统计

域名 主机 端口 网站 应用 漏洞 是否外网



ZERO TRUST SECURITY





自研感知平台：AISA-基于人工智能的态势感知



!

威胁等级 中

截止时间: 2018.09.09 12:21:00
攻击次数: 123次
攻击者: 192.168.1.1
域名: 192.168.1.1

!

威胁等级 低

截止时间: 2018.09.09 12:21:00
攻击次数: 123次
攻击者: 192.168.1.1
域名: 192.168.1.1

总体安全态势

内打内 内打外 外打内

攻击成功数量及占比

123456 攻击总数

123 攻击成功数

75% 攻击成功占比

失陷主机数量

123 失陷主机数量

告警威胁等级分布

高: 60%

中: 20%

严重: 60%

低: 60%

漏洞威胁排行

SQL 读取php源码

SQL 读取php源码

XSS

攻击源IP排行

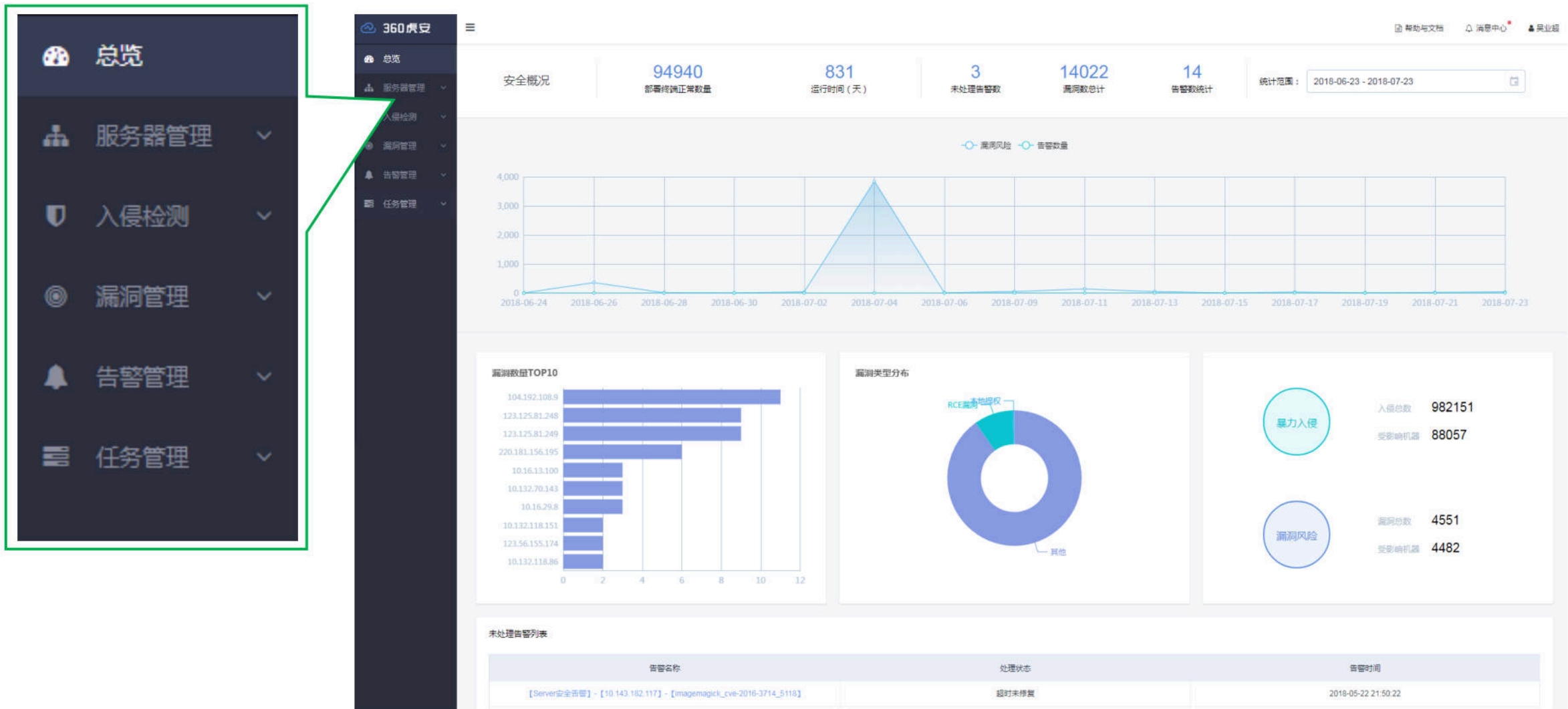
	Host	攻击次数
1	qhoo.net	123
2	huaban.com/mo7...	1234
3	qhoo.net	12345
4	qhoo.net	1234
5	qhoo.net	13

高危站点排行

	Host	被攻击次数
1	qhoo.net	123
2	huaban.com/mo7...	1234
3	qhoo.net	12345
4	qhoo.net	1234
5	qhoo.net	13

告警趋势

自研感知平台：虎安-主机监控









自研学习平台：全悉-资产数据安全风险智能分析



安全态势 — 全悉

业务线安全态势 —— PC网游 (大业务线)

态势首页 > PC网游

安全状态趋势



监控和部署



域名态势情况

	总分	服务威胁评分	历史安全评分	属性评分	应用威胁评分
高危	0	37	1	343	0
中危	32	0	3	541	0
低危	726	0	5	66	0
良好	202	923	951	10	960

服务器态势情况

	总分	服务威胁评分	历史安全评分	属性评分	应用威胁评分
高危	0	197	0	41	0
中危	79	0	0	2663	0
低危	2743	0	0	0	0
良好	3177	5802	5999	3295	5999

立体攻防演习：红蓝对抗-新彩虹

物理渗透模块

通过主动

信息收集

对目标进行被动、主动的全面信息收集。

建立威胁模型

通过模型的建立，指出企业安全弱点、风险点。

漏洞分析

对威胁模型中的风险点进行分析，对弱点位置进行分析，总结出切实可行的攻击路径。



攻击利用

采用远程线上指挥部与线下物理渗透测试人员虚实结合的方式对漏洞进行综合利用。

后渗透

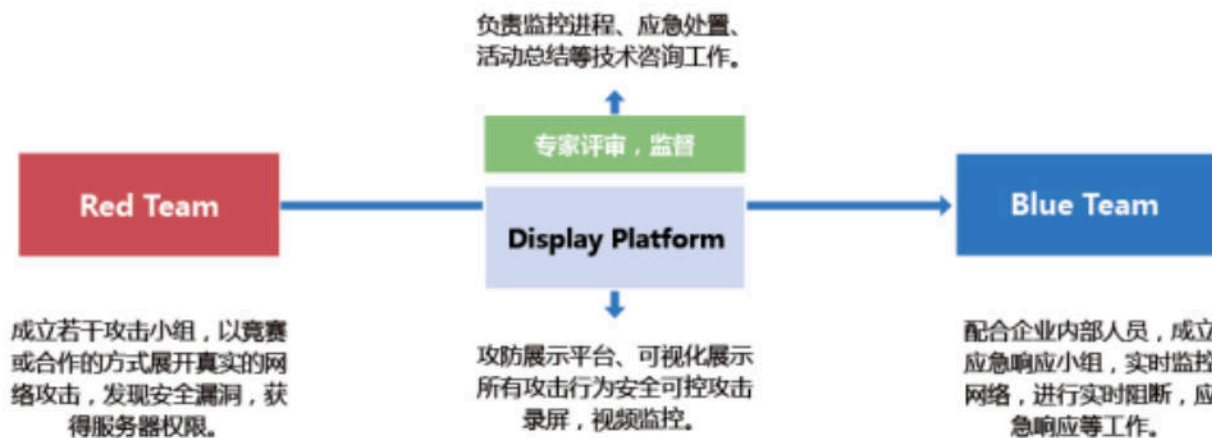
对获取到的权限进行进一步加固，进行更大范围的攻击。

报告

出具完整的物理渗透测试报告。

红蓝对抗体系架构

提升专业安全人员的侦测



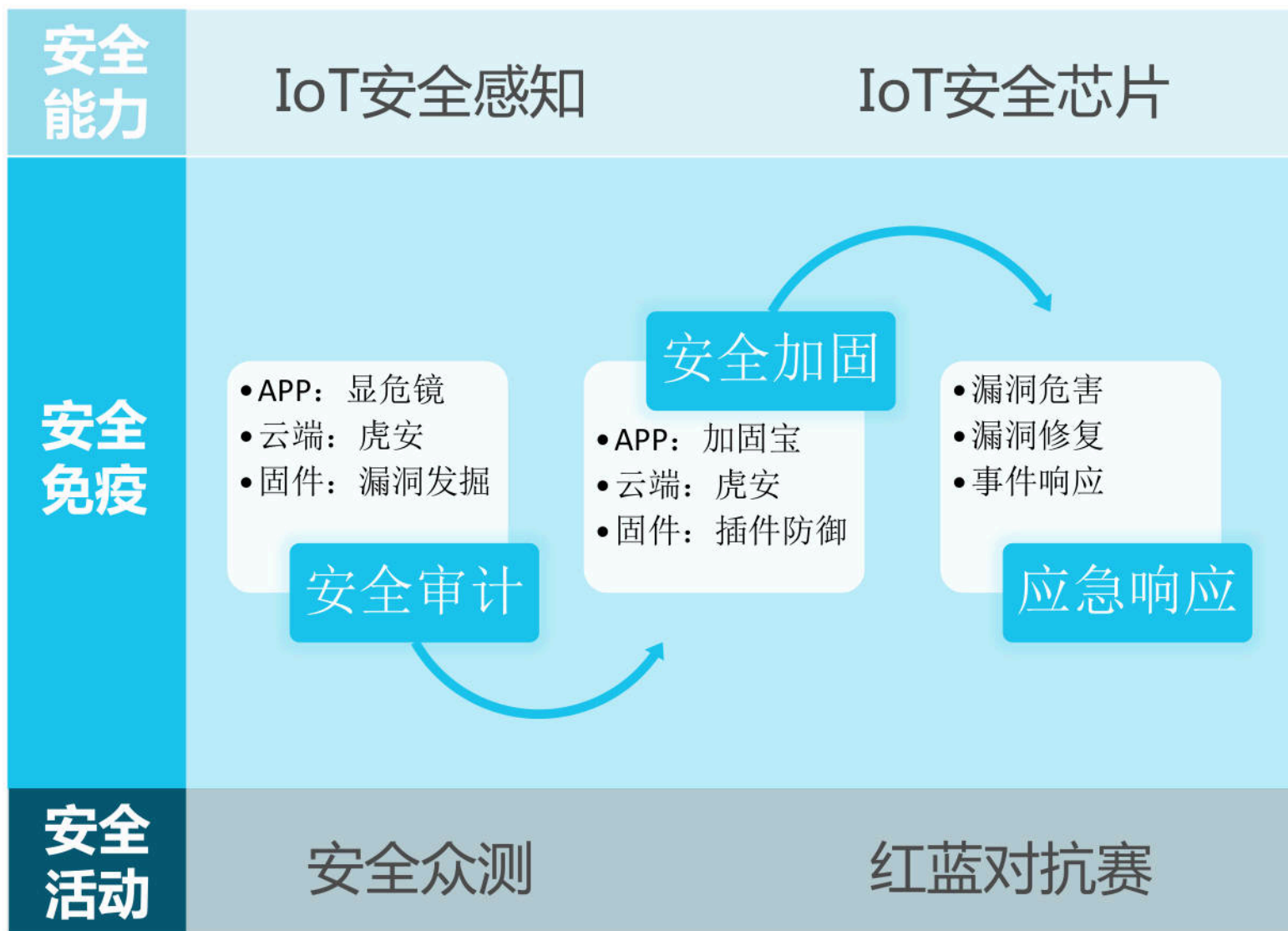
道，通过各种渗透技巧，
入目标组织内部。

的各个真实攻击面，提高
安全意识，加固整体企业

360IoT安全生态解决方案：安全赋能



360 IoT
安全生态
守护计划





ISC 互联网安全大会



360互联网安全中心

谢谢！

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China

(原“中国互联网安全大会”)